
개인정보 위험도 분석 기준 및 해설서

2020. 12.

제 · 개정 이력

순번	제·개정일	주요내용
1	(제정) 2012. 3.	개인정보 위험도 분석 기준 및 해설서
2	(개정) 2020. 12.	법령 개정에 따른 추진근거 및 일부 문구 수정

◎ 본 기준 및 해설서는 「개인정보 보호법」 제24조제3항, 제29조와 같은 법 시행령 제30조에 따른 「개인정보의 안전성 확보조치 기준」에 따라 내부망에 고유식별정보를 저장하는 경우 암호화의 적용여부 및 적용범위 결정을 위한 「위험도 분석」의 세부 기준 제시를 목적으로 합니다.

목 차

I. 개요	5
1. 추진 근거	5
2. 위험도 분석 기준이란?	6
3. 위험도 분석 기준의 구성	7
4. 위험도 분석 절차	7
 II. 위험도 분석 기준	8
1. 현황 조사	8
2. 위험도 분석 점검 항목	10
3. 위험도 분석 결과보고서	13
 III. 위험도 분석 기준 해설	14
1. 현황 조사	14
2. 위험도 분석 점검 항목	17
3. 위험도 분석 결과보고서	35

1. 추진 근거

- 「개인정보 보호법」 제24조제3항, 제29조, 같은 법 시행령 제30조 및 「개인정보의 안전성 확보조치 기준」 제7조제4항에 따라, 개인정보처리자가 내부망에 고유식별정보를 저장하는 경우 '위험도 분석 기준'에 따른 위험도 분석 결과에 따라 암호화의 적용 여부 및 적용범위를 정하여 시행할 수 있습니다.(단, 주민등록번호는 제외)

- 다만, 내부망에 주민등록번호를 저장하는 경우 '위험도 분석 기준'의 결과에 관계없이 암호화 하여야 합니다.(법 제24조의2, 같은법 시행령 제21조의2)

정의

■ 고유식별정보란?

- 주민등록번호, 여권번호, 운전면허번호, 외국인등록번호를 말한다.

- 개인정보처리자는 '개인정보 영향평가' 또는 '위험도 분석' 결과에 따라 암호화 기술의 적용 또는 이에 상응하는 조치를 이행하여야 합니다.

※ 개인정보 영향평가 : 개인정보 보호법 제33조, 시행령 제38조

참고

- 「개인정보의 안전성 확보조치 기준」 제7조(개인정보의 암호화) ① 개인정보처리자는 고유식별정보, 비밀번호, 바이오정보를 정보통신망을 통하여 송신하거나 보조저장매체를 통하여 전달하는 경우에는 이를 암호화하여야 한다.
- ③ 개인정보처리자는 인터넷 구간 및 인터넷 구간과 내부망의 중간 지점(DMZ : Demilitarized Zone)에 고유식별정보를 저장하는 경우에는 이를 암호화하여야 한다.
- ④ 개인정보처리자가 내부망에 고유식별정보를 저장하는 경우에는 다음 각 호의 기준에 따라 암호화의 적용여부 및 적용범위를 정하여 시행할 수 있다.
 1. 법 제33조에 따른 개인정보 영향평가의 대상이 되는 공공기관의 경우에는 해당 개인정보 영향평가의 결과
 2. 암호화 미적용시 위험도 분석에 따른 결과
- ⑤ 개인정보처리자는 제1항, 제2항, 제3항, 또는 제4항에 따라 개인정보를 암호화하는 경우 안전한 암호알고리즘으로 암호화하여 저장하여야 한다.
- ⑥ 개인정보처리자는 암호화된 개인정보를 안전하게 보관하기 위하여 안전한 암호 키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행하여야 한다.
- ⑦ 개인정보처리자는 업무용 컴퓨터 또는 모바일 기기에 고유식별정보를 저장하여 관리하는 경우 상용 암호화 소프트웨어 또는 안전한 암호화 알고리즘을 사용하여 암호화한 후 저장하여야 한다.

2. 위험도 분석 기준이란?

- 위험도 분석은 개인정보처리시스템에 적용하고 있는 개인정보 보호조치 이행 여부와 개인정보 유출시 정보주체의 권리를 침해할 위험의 정도를 '**위험도 분석 기준**'을 이용하여 분석하는 행위입니다.
- '**위험도 분석 기준**'은 개인정보처리자가 내부망에 고유식별정보(단, 주민등록번호 제외)를 암호화하지 않고 저장하는 경우 이행하여야 할 최소한의 보호조치 기준으로, **어느 하나의 항목**이라도 '**아니오**'에 해당하는 경우 **암호화 대상**입니다.
 - ※ 해당사항이 없는 경우 '해당없음' 항목에 체크하며 '해당없음' 체크항목도 '예'로 적용합니다.
- 개인정보처리자는 '위험도 분석 기준'에 따른 결과를 허위로 작성해서는 안되며, '위험도 분석 결과보고서'는 개인정보 보호책임자 또는 해당부서의 장의 결재를 득한 후 보관합니다.
- '**위험도 분석**'은 개인정보파일 단위로 분석하고 결과보고서를 작성하며, 개인정보파일을 위탁하여 관리하는 경우에도 위탁기관의 책임 하에 작성합니다.
 - ※ 결과보고서는 기관의 문서관리 규정에 따라 '대외비' 등으로 관리하시기 바랍니다.
- '**위험도 분석**'은 최초 분석 이후에도 해당 개인정보파일과 관련된 개인정보처리시스템의 증설, 내·외부망과 연계, 기타 운영환경 변화의 경우에 지속적으로 실시하여야 합니다.

3. 위험도 분석 기준 구성

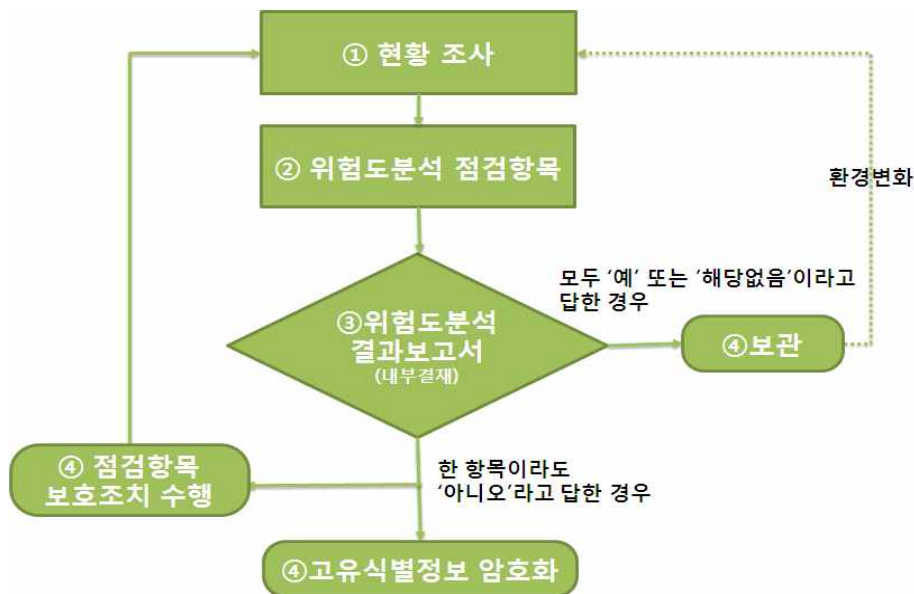
- 위험도 분석 기준은 ①현황 조사, ②위험도 분석 점검 항목, ③위험도 분석 결과 보고서로 구성되어 있습니다.



[그림 1] 위험도 분석 기준 구성

4. 위험도 분석 절차

- ① 위험도 분석을 위해 개인정보파일 및 고유식별정보 보유 여부 등 현황조사
- ② 개인정보파일 단위로 위험도 분석 점검 항목별 점검을 수행
- ③ '위험도 분석 결과보고서'를 작성하여 내부결재 후 보관
- ④ 점검 결과에 따라 고유식별정보 암호화 등을 수행



[그림 2] 위험도 분석 절차

Ⅱ

위험도 분석 기준

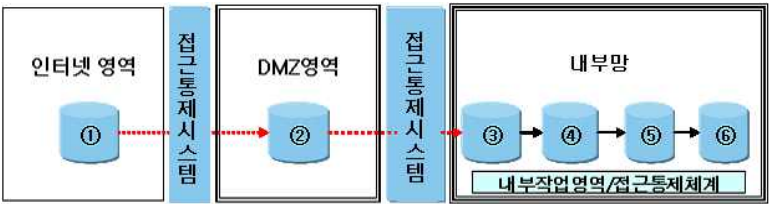
1. 현황 조사

① 개인정보파일 현황

개인정보 파일 명칭	취급개인정보	네트워크 연결여부 (개인정보파일 연동사용)	보유량 (단위:만건)	개인정보 처리시스템명
개인정보파일_1	이름, 전화번호, 주소	인터넷으로 지점 연동 (서울 ↔ 인천)	10	고객관리시스템
개인정보파일_2	이름, 전화번호, 이메일, 운전면허번호 등	OOO 업체와 개인정보파일 연동	500	교육비정산시스템
개인정보파일_3	이름, 발행일, 여권번호	OOO 행정기관과 개인정보파일 연동	1,000	여행사 업무시스템
...				

※ 상기 표에 채워진 내용은 예시이므로, 각 기관별로 상황에 맞추어 내용 작성이 필요합니다.

② 고유식별정보 현황

점 검 항 목	비 고
1. 저장하는 고유식별정보에 해당되는 항목을 모두 체크하여 주십시오. ① 여권번호 ② 운전면허번호 ③ 외국인등록번호	○ ①~③번 항목에 해당사항이 없을 경우 고유식별정보 암호화 의무 대상이 아닙니다.
2. 1번 항목에서 체크한 개인정보를 어떻게 저장하고 있습니까? ① 모든 항목 암호화 저장 ② 일부 항목 암호화 저장 ③ 암호화 하지 않고 저장	○ ①번 항목 선택 시에는 이미 암호화 중이므로 위험도 분석을 할 필요가 없습니다.
3. 개인정보파일의 저장위치는 어디 입니까? ① 인터넷 영역 ② DMZ 영역 ③ 내부망 ※ 아래 그림을 참고하여 해당 개인정보의 저장.검색.편집.정정 등을 위한 개인정보처리시스템(DB 등)이 위치하고 있는 번호에 체크하십시오. ■ ■ ■ 내부망 구성도 예시 ■ ■ ■ 	○ ①번 또는 ②번 항목 선택 시 위험도 분석 점검표와 관계없이 암호화 대상입니다.

2. 위험도 분석 점검 항목

① (기관 기준) 점검 항목

※ 개인정보파일이 포함되어 있는 개인정보처리시스템 환경에 관한 내용으로 기관 전체를 대상으로 합니다.

구 분	점 검 항 목	예	아니오	해당없음
정책기반	1. 개인정보 보호책임자를 지정하여 운영하고 있습니까?			
	2. 개인정보 보호를 위한 정책 또는 관리계획(침해 사고 대응계획 포함)을 수립·운영하고 있습니까?			
	3. 외주인력 보안관리를 위해 보안서약서 집행, 비밀번호 노출 예방 등 조치를 하고 있습니까?			
	4. DB서버에 접속하는 장비(PC, 노트북 등)에서 불법 또는 비인가된 S/W 사용을 방지하고 정품 S/W 만 사용하도록 하는 정책을 수립·운영하고 있습니까?			
	5. DB서버에 접근 가능한 자(내부직원, 위탁인력, 개발자 등) 대상으로 개인정보보호 관련 교육을 연 2회 이상 실시하고 있습니까?			
네트워크 기반	6. 상시적으로 비인가 IP주소의 접근을 통제하고 있습니까?			
	7. 상시적으로 불필요한 서비스 포트 사용을 통제하고 있습니까?			
	8. 상시적으로 불법적인 해킹시도를 방지하고, 이에 대해 모니터링을 실시하고 있습니까?			
	9. 상시적으로 바이러스, 웜 등의 네트워크 유입을 차단하고 있습니까?			
	10. 주기적으로 네트워크 접속에 대한 로그를 기록·백업하고, 분석하고 있습니까?			
	11. 네트워크 장비 및 정보보호시스템의 보안패치 발생 시 지체 없이 업데이트를 수행하고 있습니까?			

② (개인정보처리시스템 기준) 점검 항목

※ 개인정보파일이 운용되는 개인정보처리시스템의 보호조치에 관한 내용입니다.

구 분	점 검 항 목	예	아니오	해당없음
DB 및 Application 기반	12. 상시적으로 네트워크를 통한 비인가자의 DB 접근을 통제하고 있습니까?			
	13. DB서버 내에 불필요한 서비스 포트를 차단하고 있습니까?			
	14. 상시적으로 DB 접속자 및 개인정보취급자의 접속기록을 남기고 있습니까?			
	15. DB 접속기록을 주기적으로 모니터링하여 통제하고 있습니까?			
	16. DB서버에 접속하는 관리자 PC가 인터넷 접속되는 내부망의 네트워크와 분리되어 있습니까?			
	17. 개인정보취급자의 역할에 따라 DB 접근권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하고 있습니까?			
	18. 개인정보취급자의 전보, 이직, 퇴사 등 인사이동 발생 시 지체 없이 DB 접근권한을 변경하고 있습니까?			
	19. DB접속자 및 개인정보취급자의 DB 로그인 비밀번호를 최소 3개월마다 변경하고 있습니까?			
	20. DB접속자 및 개인정보취급자의 비밀번호 입력 시 5회 이상 연속 입력오류가 발생한 경우 계정 잠금 등 접근을 제한하고 있습니까?			
	21. DB 및 DB접속 어플리케이션 서버에 대한 물리적 접근을 인가된 자로 한정하고 있습니까?			
	22. DB 및 DB접속 어플리케이션 서버에서 보조저장매체(USB 등) 사용 시 관리자 승인 후 사용하고 있습니까?			
	23. DB서버 및 DB접속 어플리케이션 서버에 접속하는 모든 개인정보취급자의 단말기(PC, 노트북 등)의 운영체제 보안패치를 제조사 공지 후 지체 없이 수행하고 있습니까?			

구 분	점 검 항 목	예	아니오	해당없음
	24. 이동형 디스크 등 DB 저장매체의 불용처리 시 (폐기, 교체 등) 저장매체에 저장된 개인정보는 모두 파기하고 있습니까?			
웹(Web) 기반 ※ 웹사이트를 운영하는 경우에 만 해당	25. 신규 웹 취약점 및 알려진 주요 웹(Web) 취약점 진단/보완을 연 1회 이상 실시하거나, 상시적으로 비인가자에 의한 웹서버 접근, 홈페이지 위·변조 등을 자동으로 차단할 수 있는 보호 조치를 하고 있습니까?			
	26. 웹서버 프로그램과 운영체제 보안패치를 제조사 공지 후 지체 없이 수행하고 있습니까?			

3. 위험도 분석 결과보고서

작성일	년 월 일	작성자	(소속)	(성명)
개인정보파일명				

(작성 예시)

< 목 차 >

I. 현황 조사

1. 개인정보파일 현황 (※ 고유식별정보 항목 및 암호화 현황 포함)
2. 고유식별정보 현황
3. 네트워크 및 시스템 구성도

II. 기관 기준 보호조치 현황

1. 정책 기반 보호조치

- 조직도, 책임자, 역할 및 책임
- 내부 관리계획 및 침해사고 대응계획 수립 현황
- 외주 보안관리 현황
- S/W 사용 정책
- 개인정보취급자 교육 현황

2. 네트워크 기반 보호조치

- IP 접근통제 및 서비스 포트 제한 현황
- 정보보호시스템 운영 및 모니터링 현황
- 네트워크 바이러스 차단 현황
- 네트워크 접속기록 관리 및 분석 현황
- 네트워크 장비 및 정보보호시스템 업데이트 현황 (※ 보안패치 및 패턴갱신 등 포함)

III. 개인정보처리시스템 기준 보호조치 현황

1. DB 및 Application 기반 보호조치

- DB 접근 통제 현황
- DB서버 서비스 포트 제한 현황
- DB 접속기록 관리 및 모니터링 현황
- 관리자 PC 네트워크 분리 현황
- DB접근 권한 부여 현황 및 변경·말소 내역
- 비밀번호 관리 정책 및 현황
- 물리적 접근 통제 현황
- 보조저장매체 이용 관리 현황
- 운영체제 보안패치 현황 (※ DB서버 및 DB서버 접속 단말기 포함)
- DB저장매체 불용처리 절차 및 현황

2. 웹 기반 보호조치

- 웹 취약점 점검 현황 및 결과 (※ 조치결과, 주기적 점검계획 등 포함)
- 웹 서버 보호조치 현황 (※ 웹방화벽 운영현황 등)

IV. 위험도 분석 결과

- 위험도 분석 점검에 의한 암호화 여부 판정 결과 등

Ⅲ 위험도 분석 기준 해설

1. 현황 조사

1-1. 개인정보파일 현황

개인정보 파일 명칭	취급개인정보	네트워크 연결여부 (개인정보파일 연동사용)	보유량 (단위:만건)	개인정보 처리시스템명
개인정보파일 (예시)	이름, 전화번호, 이메일, 운전면허번호 등	○○○ 업체와 개인정보파일 연동	500	운전면허번호 조회시스템
...				
개인정보파일_n				



- “개인정보파일 현황”은 개인정보처리시스템을 기준으로 해당 시스템이 보유하고 있는 개인정보파일 목록을 기재합니다.
- 각 개인정보파일별 취급하는 개인정보 항목, 네트워크 연결여부, 개인정보 보유량 등을 기재하고 해당 개인정보파일이 운영되고 있는 개인정보처리시스템 명을 기재합니다.
- 위험도 분석 점검의 단위인 ‘개인정보파일’이란 반드시 DB테이블 단위로 구분되는 것은 아닙니다. 업무단위 또는 정보시스템의 기능 목록명 또는 프로세스명으로 분류하여 고유식별정보를 저장하는 DB테이블을 통합하여 점검 가능합니다.



■ ‘개인정보파일’이란 ?

- 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물(集合物)을 말한다.

【예시】 '○○ e-러닝시스템'이란 시스템이 있다면, 강사목록 테이블, 수강생목록 테이블 등을 교육관리라는 업무로 분류하여 위험도 분석을 할 수 있습니다.

1-2. 고유식별정보 현황

1. 저장하는 고유식별정보에 해당되는 항목을 모두 체크하여 주십시오.

- ① 여권번호 ② 운전면허번호 ③ 외국인등록번호

해설

- 위험도 분석은 내부망에 고유식별정보를 저장할 경우, 암호화의 적용여부 및 적용 범위를 결정하는 기준이므로 해당 개인정보파일에서 고유식별정보를 저장하고 있는지 점검하여 체크합니다.
 - 다만, 내부망에 주민등록번호를 저장하는 경우 '위험도 분석 기준'의 결과와 관계 없이 암호화 하여야 합니다.
- 해당사항이 없을 경우 고유식별정보 암호화 의무 대상이 아니므로 위험도 분석을 중단할 수 있습니다.

2. 1번 항목에서 체크한 개인정보를 어떻게 저장하고 있습니까?

- ① 모든 항목 암호화 저장 ② 일부 항목 암호화 저장 ③ 암호화 하지 않고 저장

해설

- ①번 : 해당 개인정보파일에서 저장하고 있는 모든 고유식별정보를 암호화하여 저장하는 경우 선택
 - ②번 : 여러 고유식별정보 중 일부 항목만 암호화하여 저장하는 경우 선택
 - ③번 : 모든 고유식별정보를 암호화하지 않고 저장하는 경우 선택
 - ①번 항목 선택 시 모두 암호화 중이므로 위험도 분석을 수행할 필요가 없습니다. 단, 고유식별정보를 암호화하는 경우 국내 및 미국, 일본, 유럽 등의 국내·외 암호 연구 관련기관에서 권고하는 알고리즘으로 암호화하여야 합니다.
 - 안전한 암호 알고리즘을 사용하더라도 암호화 키가 잘못 관리되는 경우에는 암호화된 정보들이 유·노출될 수 있으므로 이를 안전하게 관리하여야 합니다.
- ※ 암호 키 관리의 상세 내용은 "암호 키 관리 안내서"(14.12월, 한국인터넷진흥원) 등 참고

3. 개인정보파일의 저장위치는 어디 입니까?

- ① 인터넷 영역 ② DMZ 영역 ③ 내부망

※ 아래 그림을 참고하여 해당 개인정보의 저장.검색.편집.정정 등을 위한 개인정보처리시스템 (DB 등)이 위치하고 있는 번호에 체크하십시오.

■■■ 내부망 구성도 예시 ■■■

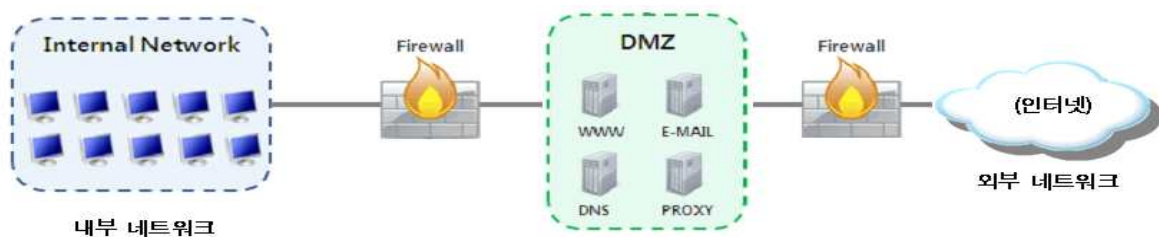


해설

■ 용어 정의

- 인터넷 영역 : 개인정보처리시스템과 인터넷이 직접 연결되어 있는 구간입니다.
- DMZ 영역 : 인터넷 구간과 내부망 구간 사이에 위치한 중간 지점으로 침입차단 시스템 등으로 접근제한 등을 수행하지만 외부망에서 직접 접근이 가능한 영역을 말합니다.
- 내부망 : 인터넷 구간과 물리적으로 망이 분리되어 있거나, 비인가된 불법적인 접근을 차단하는 기능 등을 가진 접근통제시스템에 의하여 인터넷 구간에서의 직접 접근이 불가능하도록 통제·차단되어 있는 구간을 말합니다.

■■■ 네트워크 구성도 예시 ■■■



- ①번 또는 ②번 항목 선택 시, 위험도 분석과 상관없이 무조건 암호화 대상입니다. 인터넷 영역이나 DMZ 영역은 외부에서 직접 접근이 가능하므로 외부 침입의 위험성이 크기 때문에 이 영역에 고유식별정보를 저장하려는 경우 반드시 암호화해야 합니다.

2. 위험도 분석 점검 항목

2-1. (기관 기준) 점검 항목

2-1-1 정책기반

1. 개인정보 보호책임자를 지정하여 운영하고 있습니까?

취 지

- 개인정보 보호책임자를 지정하는 것은 형식적인 절차가 아닌 개인정보처리자의 내부 관리체계를 강화하고, 개인정보의 안전한 관리가 가능하도록 하는 취지입니다. 이를 위해 전문지식을 보유하고 보호조치 수행이 가능한 개인정보 보호책임자를 지정하여 운영합니다.

해 설

- 개인정보 보호법 제31조제1항 및 같은 법 시행령 제32조에 따라 개인정보의 처리에 관한 업무를 총괄해서 책임질 개인정보 보호책임자(CPO : Chief Privacy Officer)를 지정해야 합니다.

참 고

- 개인정보 보호책임자는 개인정보 관련 업무경력과 개인정보 관련 전문지식을 모두 보유한 사람으로 개인정보 처리업무를 자신의 책임 하에 관리할 수 있는 직위를 가져야 합니다.(자세한 자격요건은 시행령 제32조제2항 참조)
 - 개인정보 보호책임자는 개인정보처리에 관한 전반적인 사항을 결정하고 이로 인한 제반 결과에 대하여 책임을 지는 자이므로 개인정보 수집·이용·제공 등에 대하여 실질적인 권한을 가지고 있어야 합니다.
 - 개인정보 처리업무 경험이 있는 자로서, 개인정보 보호를 위한 관리적·기술적·물리적 보호조치를 할 수 있는 사람이어야 합니다.
- 개인정보 보호책임자가 실무를 담당하지 않는 경우, 개인정보의 기술적·관리적·물리적 조치를 실행할 수 있는 개인정보 보호담당자를 지정하여 업무를 수행합니다.
- 개인정보 보호책임자의 지정, 역할, 책임에 관한 내용은 내부관리계획 등에 명시하여 최고 경영층으로부터 승인받습니다.

- 조직도, 책임자, 역할 및 책임 등이 명시된 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

2. 개인정보 보호를 위한 정책 또는 관리계획(침해사고 대응계획 포함)을 수립·운영하고 있습니까?

취 지

- 개인정보보호 활동이 임기응변식이 아니라 체계적이고 전사적인 계획 내에서 수행될 수 있도록 하는데 목적이 있으므로 당해 조직의 구성원 전체에 통용되는 내부 규정을 마련합니다.

해 설

- 개인정보보호를 위한 정책 또는 관리계획이란 개인정보처리자가 개인정보를 안전하게 처리하기 위하여 내부 의사결정 절차를 통하여 수립·시행하는 내부 기준으로 내부관리계획, 개인정보보호 추진계획 등 개인정보보호 관련 각종 내부 계획, 지침, 규정 등을 의미합니다.
- 특히, 개인정보 침해사고에 대비하여 침해사고 시 대응 절차, 담당자, 피해복구조치 등 침해 대응계획이 포함되어야 합니다.
- 개인정보보호 정책 및 침해사고 대응계획 수립현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

3. 외주인력 보안관리를 위해 보안서약서 집행, 비밀번호 노출 예방 등 조치를 하고 있습니까?

취 지

- 조직에서 구성원들의 개인정보 유출 위험을 최소화하고, 구성원에게 개인정보보호에 대한 책임을 명확히 주지시키기 위해 문서화한 보안서약서에 서명하도록 해야 하며, 개인정보를 취급하는 외주 인력도 보안관리 대상에서 제외되지 않도록 합니다.

해설

- '개인정보취급자'는 기업·단체·공공기관의 임직원, 계약직원, 아르바이트 직원 등의 시간제 근로자뿐만 아니라 외부기관에서 또는 외부기관으로 파견된 근로자 등도 해당됩니다.
- 최근의 개인정보 유출사례를 보면 개인정보취급자에 대한 관리 소홀, 특히 외주 인력에 대한 보안관리 소홀이 그 원인이 되는 경우가 많으므로 보안서약서 집행, 비밀번호 노출 예방 등 외주 인력의 보안관리 조치를 수행하여 개인정보 유출을 방지합니다.
- 외주 보안관리 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

4. DB서버에 접속하는 장비(PC, 노트북 등)에서 불법 또는 비인가된 S/W 사용을 방지하고 정품 S/W만 사용하도록 하는 정책을 수립·운영하고 있습니까?

취지

- 불법 S/W 사용은 악성코드 침투 경로로 이용되어 악성코드에 의한 개인정보 유출 사고가 발생할 수 있습니다. 따라서 개인정보의 안전한 관리를 위하여 정품 S/W를 사용합니다.

해설

- 운영체제 S/W의 경우, 불법복제 S/W는 정품 인증을 받지 못함에 따라 신규 보안 위협 제거를 위한 업데이트 지원을 받지 못하게 되어 운영체제 취약점을 이용한 악성코드 감염으로 대량의 개인정보 유출 피해가 발생할 수 있습니다. 따라서, DB 서버에 접속하는 장비 또는 개인정보취급자의 PC에는 정품 S/W만을 사용하도록 하는 정책을 수립합니다.
- S/W 사용정책 및 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

5. DB서버에 접근 가능한 자(내부직원, 수탁자, 개발자 등) 대상으로 개인정보보호 관련 교육을 연 2회 이상 실시하고 있습니까?

- 개인정보처리자는 개인정보취급자의 개인정보보호에 대한 인식을 제고시키기 위해 매년 정기적으로 개인정보보호 교육을 실시합니다.
- 특히, 고유식별정보가 저장된 DB서버에 접근 가능한 자에 대해서는 최소 연2회 이상 교육을 실시합니다.

 해 설

- 최근의 유출사례에서 볼 수 있듯이 개인정보 유출은 내부직원의 보안의식 부재에 의한 경우가 많기 때문에 개인정보취급자에 대한 연 2회 이상의 교육을 실시합니다.
※ 예시 : 내부 직원이 고객정보를 출력물로 유출, 직원 실수로 고객정보가 포함된 이메일 발송

참 고

■ 개인정보취급자

- 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 업무를 담당하는 자로서 임직원, 파견근로자, 시간제근로자 등을 말한다.(표준개인정보처리방침 제2조제6호)
 - 개인정보취급자는 개인정보 처리 업무를 담당하고 있는 자라면, 정규직, 비정규직, 하도급, 시간제 등 모든 근로 형태를 불문한다. 고용관계가 없더라도 실질적으로 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 자는 개인정보취급자에 포함된다.(개인정보 보호법령 및 지침·고시 해설서)
- 정기적인 개인정보취급자 교육을 통해 개인정보가 안전하게 관리될 수 있도록 개인정보취급자의 개인정보 보호에 대한 인식을 제고시키고 개인정보보호 대책의 필요성을 이해시킵니다.
 - 교육방법은 집체교육 뿐 아니라 조직의 환경을 고려하여 인터넷 교육, 그룹웨어 교육 등 다양한 방법을 활용하여 실시하도록 하고, 필요한 경우 외부 전문기관이나 전문 인력에게 위탁하여 교육을 실시할 수 있습니다.
※ '일일 업무 회의 시 과내 약식으로 수행되는 전달교육' 등은 개인정보보호 교육에 해당하지 않으며 반드시 독립된 교육과정 또는 교과목으로 개인정보 보호 목적에 부합되도록 수행되어야 합니다.
 - 교육내용에는 업무를 수행함에 있어 필요한 개인정보 관련 기술교육뿐만 아니라 개인정보 보호관련 법률 및 제도, 사내규정 등 반드시 알고 있어야 하는 기본적인 내용을 포함하는 등 목적에 부합하도록 교육을 실시합니다.

참 고

■ 개인정보보호 교육내용 예시

- 개인정보 보호의 중요성
- 내부 관리계획의 제·개정에 따른 준수 및 이행
- 위험 및 대책이 포함된 조직 보안 정책, 보안지침, 지시 사항, 위험관리 전략
- 개인정보처리시스템의 안전한 운영·사용법(하드웨어, 소프트웨어 등)
- 개인정보의 안전성 확보조치 기준
- 개인정보 보호업무의 절차, 책임, 방법
- 개인정보 처리 절차별 준수사항 및 금지사항
- 개인정보 유·노출 및 침해신고 등에 따른 사실 확인 및 보고, 피해구제 절차 등

- 교육 목적, 대상, 내용, 일정 및 방법 등을 포함하는 '00년 개인정보보호 교육계획', 교육결과보고 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

2-1-2. 네트워크(N/W) 기반

6. 상시적으로 비인가 IP주소의 접근을 통제하고 있습니까?

취 지

- IP 접근통제의 목적은 개인정보처리시스템에 대해 인가되지 않는 접근을 차단하여 개인정보의 불법사용, 누출, 변조, 훼손 등의 위험을 적절히 차단하는 것입니다.

해 설

- 침입차단시스템(Firewall) 또는 침입방지시스템(IPS : Intrusion Prevention System) 등의 설치·운영을 통해 불법적인 접근을 IP주소 등으로 제한할 수 있으며 개인정보처리 시스템에 대한 불법적인 개인정보 유출시도를 탐지합니다.
- IP 접근통제 현황을 '위험도 분석 결과보고서'에 첨부합니다.

7. 상시적으로 불필요한 서비스 포트 사용을 통제하고 있습니까?

취 지

- 서비스와 상관없는 포트가 불필요하게 개방되어 있는 경우 불법 침입의 경로로 이용될 수 있으므로 서비스에 꼭 필요한 포트만 사용하도록 통제합니다.

해 설

- 불필요한 서비스 포트는 침입차단시스템(Firewall), 서버 설정 등으로 차단, 악성코드 유입 및 불법 침입 경로를 차단합니다.
- 서비스 포트 제한 현황 등을 '위험도 분석 결과보고서'에 첨부합니다.

8. 상시적으로 불법적인 해킹시도를 방지하고, 이에 대해 모니터링을 실시하고 있습니까?

취 지

- 침입차단시스템 및 침입탐지 기능을 갖춘 설비를 설치해야 하는 것은 물론이고, 이에 대한 상시 모니터링이 함께 이루어져야 불법적인 해킹시도에 대한 대응이 가능합니다.

해 설

- 침입탐지시스템, 침입방지시스템 등의 정보보호시스템을 갖추고, 모니터링을 수행하여 불법적인 해킹시도를 상시 방지합니다.
- 정보보호시스템 운영 모니터링 현황을 '위험도 분석 결과보고서'에 첨부합니다.

9. 상시적으로 바이러스, 웜 등의 네트워크 유입을 차단하고 있습니까?



- 바이러스, 웜 등 악성 프로그램들이 네트워크를 통해 유입되어 감염될 경우 해킹에 의한 개인정보 유출의 통로로 이용될 수 있으므로 네트워크상에서 상시적으로 악성 프로그램 검사를 수행하여 유입을 차단합니다.



- 네트워크를 통해 유입되는 콘텐츠의 바이러스 감염 여부를 검사하고 차단 및 치료할 수 있는 바이러스 방지 솔루션을 설치·운영합니다.
- 네트워크 바이러스 차단 현황 등을 '위험도 분석 결과보고서'에 첨부합니다.

10. 주기적으로 네트워크 접속에 대한 로그를 기록·백업하고, 분석하고 있습니까?



- 네트워크 접속 로그 파일을 생성함으로써 불법적인 접근 및 행위를 확인 가능하고 유출사고 발생 시 책임추적성을 확보할 수 있습니다.



- Access log 등을 기록·백업하고 주기적으로 분석하여 이상 징후를 파악하고 대응합니다.
- 네트워크 접속기록 관리 및 분석 현황 등을 '위험도 분석 결과보고서'에 첨부합니다.

11. 네트워크 장비 및 정보보호시스템의 보안패치 발생 시 지체 없이 업데이트를 수행하고 있습니까?

 취 지

- 네트워크 장비, 정보보호시스템은 항상 최신 업데이트를 유지하여 신규로 발생하는 보안 위협에 대응합니다.

 해 설

- 라우터, 스위치 등 네트워크 장비 및 침입차단시스템(Firewall), 가상사설망(VPN), 침입 방지시스템(IPS) 등 정보보호시스템 운영 시 환경설정, 보안정책 설정, 침입패턴 등을 최신으로 유지할 수 있도록 업데이트를 수행하고 취약점 발견 등으로 인한 보안패치 발생 시 업데이트를 수행합니다.
- '지체 없이'란 현재 운영 중인 응용프로그램과의 업무연속성, 시스템에 미칠 영향 등을 고려하여 적용하기까지 소요되는 합리적인 시간을 의미합니다.
- 네트워크 장비 및 정보보호시스템 업데이트 현황을 '위험도 분석 결과보고서'에 첨부합니다.

2-2. (개인정보처리시스템 기준) 점검 항목

2-2-1. DB 및 Application 기반

12. 상시적으로 네트워크를 통한 비인가자의 DB 접근을 통제하고 있습니까?

취 지

- 방화벽 등 네트워크 단의 침입차단시스템이 잘 운용되고 있는 상황이라도 DB에 대한 비인가자의 접근통제는 별도로 실시합니다.

해 설

- 상시적으로 비인가자에 대한 DB접근을 통제하기 위하여 DB접근제어 솔루션 등을 이용할 수 있습니다.
- 사용자가 DBMS에 로그인하거나 SQL을 수행하려고 할 때 미리 정의된 규칙에 따라 권한 여부를 판단하여 통제합니다.
- DB접근통제 현황을 위험도 분석 보고서에 첨부합니다.

13. DB서버 내에 불필요한 서비스 포트를 차단하고 있습니까?

취 지

- 서비스와 상관없는 포트가 불필요하게 개방되어 있는 경우 불법 침입의 경로로 이용될 수 있으므로 서비스에 꼭 필요한 포트만 사용하도록 통제합니다.

해 설

- 관리자가 DB관리를 위해 사용해야하는 포트, 어플리케이션 서버에서 DB연결을 위해 필요한 포트 등 꼭 필요한 포트 이외는 차단하여 악성코드 유입 및 불법 침입 경로를 차단합니다.
- 서비스 포트 제한 현황 등을 '위험도 분석 결과보고서'에 첨부합니다.

14. 상시적으로 DB 관리자 및 개인정보취급자의 접속기록을 남기고 있습니까?

취 지

- DB 접속 및 개인정보 처리내역 등을 자동으로 기록하는 로그 파일을 생성함으로써 불법적인 접근 및 행위를 확인 가능하고 유출사고 발생 시 책임추적성을 확보합니다.

해 설

- 내부관리자가 DB관리 툴, Telnet등을 이용해 DB에 직접 접속하는 경우와 개인정보취급자가 Web 또는 응용프로그램을 통해 접속하는 경우 모두 접속기록을 남겨야 합니다.
- DB 접속기록 관리 현황을 '위험도 분석 결과보고서'에 첨부합니다.

15. DB 접속기록을 주기적으로 모니터링하여 통제하고 있습니까?

취 지

- DB접속기록에 대한 모니터링 과정 없이 단순히 DB접속기록을 남기는 것만으로는 DB접속자의 행위에 대한 효과적인 통제가 이루어진다고 할 수 없습니다. 접속기록의 주기적인 모니터링을 실시하면 DB접속에 대한 이상 징후를 파악하여 조치가 가능하고, DB에 접속하는 모든 사람에게 모니터링이 이루어지고 있음을 인지시킴으로써 불법적인 시도 자체를 줄일 수 있습니다.

해 설

- 매주 DB 접속에 대한 이상 징후가 있는지 DB접속기록에 대해 최소 주 1회 이상 모니터링을 수행합니다.
 - ※ DB에 접속한 개인정보취급자의 최대 접속시간 제한, 일정 시간 동안 업로드·다운로드 양 제한 등 비정상 처리 통제 정책이 준수되고 있는지 여부 모니터링 포함
- DB 접속기록 모니터링 현황을 '위험도 분석 결과보고서'에 첨부합니다.

16. DB서버에 접속하는 관리자 PC가 인터넷 접속되는 내부망의 네트워크와 분리되어 있습니까?

취 지

- DB관리자의 PC에 악성코드가 삽입되면 DB관리자 계정이 탈취되어 대규모 개인정보 유출사고가 발생할 수 있습니다.
- DB 관리자의 PC에서 인터넷 접속이 이루어질 경우 악성코드에 감염되어 해킹 경로로 이용될 수 있으므로 DB 관리자 PC는 인터넷 접속이 되지 않도록 합니다.

해 설

- DB관리자 PC가 인터넷 접속으로 악성코드에 감염된 채 DB서버에 접속할 수 없도록 DB에 접속하는 DB관리자 PC는 인터넷 접속이 불가능하도록 접속을 차단합니다.
- DB관리자 PC의 망 분리는 네트워크를 별도로 구축하는 물리적 망 분리 외에 가상화를 이용한 논리적 망분리도 가능합니다.
- DB관리자 PC의 네트워크 분리 현황 등을 '위험도 분석 결과보고서'에 첨부합니다.

17. 개인정보취급자의 역할에 따라 DB 접근권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하고 있습니까?

취 지

- 접근권한 관리의 목적은 개인정보처리시스템에 대하여 업무 목적 외 불필요한 접근을 차단하여 개인정보의 도난, 유출, 변조, 훼손을 방지하기 위한 것입니다.

해 설

- 개인정보취급자의 역할에 따라 조회, 등록, 수정, 삭제 등의 권한을 업무수행 목적에 따라 최소한의 범위로 차등 부여합니다.
- 접근권한은 업무 단위 수준에서 차등 부여하면 됩니다.
※ 예시 : 회계부서는 영업부서 화면에 접근하지 못하도록 권한 부여
- 개인정보취급자 계정 관리 정책, 권한부여·변경 내역을 '위험도 분석 결과보고서'에 첨부합니다.

18. 개인정보취급자의 전보, 이직, 퇴사 등 인사이동 발생 시 지체 없이 DB 접근 권한을 변경하고 있습니까?

취 지

- 인사이동 등으로 개인정보취급자가 아닌 사람이 계속 개인정보처리시스템에 접근 가능 한 경우, 업무목적 외 불필요한 접근으로 인해 악의적 사용 및 유출 등의 문제가 발생할 수 있습니다. 개인정보취급자의 역할 변경 시 철저한 접근권한 통제가 이루어지도록 합니다.
- 개인정보취급자의 전보, 휴직, 퇴사 등 인사이동 발생 시, 원칙적으로는 즉시 DB 접근권한을 변경, 삭제 등을 수행하도록 하나, 업무인수인계(전보) 등으로 인하여 불가피한 경우에는 지체 없이 변경 등을 수행하도록 합니다.

해 설

- 개인정보취급자의 전보, 휴직, 퇴사 등으로 인해 계정의 변경·삭제가 필요한 경우 즉시 계정 삭제 및 패스워드 변경 등 DB 접근권한을 변경합니다.
- 접근권한 변경 시, 일회성 조치로 제외되는 경우가 생기지 않도록 공식적인 사용자 계정 관리 절차에 따라 통제될 수 있도록 합니다.
- '지체 없이'란 조직원의 전보, 휴직, 퇴사 등으로 인한 인사이동 발생 후 접근권한을 변경하기까지 소요되는 합리적인 시간을 의미합니다.
- 개인정보취급자 계정 관리 정책, 권한부여·변경 내역을 '위험도 분석 결과보고서'에 첨부합니다.

19. DB접속자 및 개인정보취급자의 DB 로그인 비밀번호를 최소 3개월마다 변경하고 있습니까?

취 지

- 비밀번호를 장기간 사용할 경우, 그만큼 비밀번호 해킹의 가능성도 높아지므로 비밀번호의 유효기간을 설정하여 최소 3개월마다 변경합니다.

해설

- DB에 직접 접속하는 DB 이용자 계정의 비밀번호 유효기간을 3개월 이하로 설정하여 비밀번호를 변경합니다.
- 개인정보취급자의 개인정보처리시스템 로그인시 유효기간을 설정 기능을 두어 3개월 마다 강제 변경합니다.
- DB접속자 및 개인정보취급자의 비밀번호에 대한 점검 항목이며 미들웨어 등에서 사용하는 DB 비밀번호는 적용 대상이 아닙니다.
- 비밀번호 관리 정책 및 현황을 증적자료로 '위험도 분석 결과보고서'에 첨부합니다.

20. DB접속자 및 개인정보취급자의 비밀번호 입력 시 5회 이상 연속 입력오류가 발생한 경우 계정 잠금 등 접근을 제한하고 있습니까?

취지

- DB 이용자 계정과 개인정보취급자의 이용자 계정은 비밀번호 해킹을 통한 개인정보 유출 위험이 발생할 수 있으므로 일정 횟수 이상 연속 입력 오류가 발생한 경우에는 접근을 차단합니다.

해설

- 계정 잠금 기능이 제공되지 않는 경우 공격자는 해당 계정의 패스워드를 파악할 때까지 지속적인 Brute force attack을 수행할 수 있습니다.

참고

■ 무차별 대입 공격 (Brute force attack)

- 성공할 때까지 가능한 모든 조합의 경우의 수를 시도해 원하는 공격을 시도하는 것
(예) Crack 등 소프트웨어를 이용하여 계정에 대한 password를 추측하는 방법
- DB관리자 등 DB에 직접 접속하는 경우, DBMS의 비밀번호 입력횟수 제한 기능을 사용합니다. 기능을 제공하지 않는 DBMS를 사용하는 경우에 한하여 DB서버의 입력횟수 제한 기능을 사용할 수 있습니다.
- 계정 잠금에 따라 서비스가 신속히 이루어 질 수 있도록 잠금 해제 절차를 수립합니다.
- DB접속자 및 개인정보취급자의 비밀번호에 대한 점검항목이며 미들웨어 등에서 사용하는 DB 비밀번호는 적용 대상이 아닙니다.
- 비밀번호 관리정책 및 현황 등을 증적자료로 '위험도 분석 결과보고서'에 첨부합니다.

21. DB 및 DB접속 어플리케이션 서버에 대한 물리적 접근을 인가된 자로 한정하고 있습니까?

 취 지

- 개인정보처리시스템의 서버에 비인가자의 물리적 접근이 가능한 경우, 개인정보의 절도, 파괴 등의 위험이 발생할 수 있으므로 물리적 접근통제를 실시합니다.

 해 설

- 전산실 등 개인정보를 보관하고 있는 물리적 보관 장소를 별도로 두고 있는 경우 출입을 통제하는 방법으로 물리적 접근통제 장치를 설치·운영하고 이에 대한 출입 내역을 전자적인 매체 또는 수기문서 대장에 기록하는 방법 등이 있습니다.
 - 전자적 매체 기록방법 : 비밀번호 기반 출입통제 장치, 스마트카드 기반 출입 통제 장치, 지문 등 바이오정보 기반 출입통제 장치 등
 - 수기문서 대장 기록방법 : '출입자', '출입일시', '출입목적' 등을 출입관리 대장에 기록
- DB 서버 및 DB 접속 어플리케이션 서버에 대한 비인가자 접근을 차단하기 위해 접근 통제 절차를 수립·운영하여야 하며, 접근기록을 보관합니다.
 - ※ 접근 통제 절차에는 출입증·출입카드 발급절차, 회수절차 등 포함
- DB 서버 및 DB 접속 어플리케이션 서버를 별도의 전산실에서 운영하지 않는 경우 비인가자가 무단접근하지 못하도록 통제선, 칸막이 등을 이용하여 비인가자 접근을 차단하여야 합니다.
- 개인정보처리시스템에 대한 물리적 접근통제 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

22. DB 및 DB접속 어플리케이션 서버에서 보조저장매체(USB 등) 사용 시 관리자 승인 후 사용하고 있습니까?

 취 지

- 방화벽, 침입탐지 등 네트워크 접근제한 솔루션을 운용한다하더라도 DB서버 등에 보조저장매체 직접 접근으로 해킹프로그램을 구동하거나 개인정보의 직접 유출이 가능할 수 있으므로 이를 방지하여야 합니다.

정의

■ 보조저장매체란?

- 이동형 디스크, USB 메모리 등 자료를 저장할 수 있는 매체로서 개인정보처리시스템 또는 개인용 컴퓨터 등과 용이하게 연결·분리할 수 있는 저장매체를 말한다.

- DB서버나 DB접속 어플리케이션 서버에 직접 보조저장매체 삽입을 차단하고 불가피하게 업무목적으로 쓸 경우 관리자 허가를 받는 절차를 거쳐야 합니다.
- 관리자는 보조저장매체의 사용 및 회수를 통제하여야 하며, 최신 백신 소프트웨어로 악성코드 감염여부를 확인하는 등 보안조치를 확인 후 사용을 허가하고 관리자 승인 내역을 전자적인 매체 또는 수기문서 대장에 기록하여야 합니다.
- 보조저장매체 이용관리 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

23. DB서버 및 DB접속 어플리케이션 서버에 접속하는 모든 개인정보취급자의 단말기(PC, 노트북 등)의 운영체제 보안패치를 제조사 공지 후 지체 없이 수행하고 있습니까?

 취지

- 보안패치는 운영체제나 응용프로그램에 내재된 보안 취약점을 보완하는 소프트웨어로 보안패치를 할 경우 취약점을 악용하는 악성코드 감염을 방지합니다.

- 운영체제나 응용프로그램의 보안 취약점은 해커에 의한 공격 경로를 제공할 수 있으므로 운영체제 제조사 등에서 업데이트 공지가 있는 경우 최신 보안패치를 적용합니다.
- '지체 없이'란 개인정보취급자의 단말기(PC, 노트북 등)의 운영체제 보안패치에 대한 제조사 공지 후 적용하기까지 소요되는 합리적인 시간을 의미합니다.
- DB 접속 단말기의 운영체제 보안패치 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

24. 이동형 디스크 등 DB 저장매체의 불용처리 시(폐기, 교체 등) 저장매체에 저장된 개인정보는 모두 파기하고 있습니까?

 취 지

- 저장매체의 폐기, 교체 등 불용처리로 저장매체에 저장된 개인정보는 모두 파기해서 외부에 노출되지 않도록 해야 하며, 복구될 수 없도록 완전하게 삭제해야 합니다. 암호화되지 않은 개인정보가 저장매체의 불용처리로 인해 외부에 반출되거나 복구될 경우 개인정보 유출 위험이 있습니다.

 해 설

- 파일을 삭제하거나 이동형 디스크를 포맷한 후 중고로 매매하는 경우가 종종 있으나, 파일 삭제 또는 이동형 디스크 포맷만으로는 데이터 영역이 완전하게 삭제되지 않아 복구될 수 있습니다. 중고 이동형 디스크에 개인정보가 남아있을 경우 개인정보 오·남용의 위험성이 있으므로 이를 방지하기 위한 다음 중 어느 하나의 조치가 필요합니다.

- 완전파괴(소각·파쇄 등)

※ 예시 : 개인정보가 저장된 회원가입신청서 등의 종이문서, 이동형 디스크나 자기테이프를 파쇄기로 파기하거나 용해, 또는 소각장, 소각로에서 태워서 파기 등

- 전용 소자장비를 이용하여 삭제

※ 예시 : 디가우저(Degausser)를 이용해 이동형 디스크나 자기테이프에 저장된 개인정보 삭제 등

- 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행

※ 예시 : 개인정보가 저장된 이동형 디스크에 대해 완전포맷(3회 이상 권고), 데이터 영역에 무작위 값(0, 1 등)으로 덮어쓰기(3회 이상 권고), 해당 드라이브를 안전한 알고리즘 및 키 길이로 암호화 저장 후 삭제하고 암호화에 사용된 키 완전 폐기 및 무작위 값 덮어쓰기 등

- DB저장매체 불용처리 절차 및 현황 등 관련 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

2-2-2. 웹(Web) 기반

25. 신규 웹 취약점 및 알려진 주요 웹(Web) 취약점 진단/보완을 연 1회 이상 실시하거나, 상시적으로 비인가자에 의한 웹서버 접근, 홈페이지 위·변조 등을 자동으로 차단할 수 있는 보호 조치를 하고 있습니까?

취 지

- 개인정보가 내부망에 존재할 때 외부에서의 접근은 불가능하지만 외부에 의해 해킹이 일어나는 경우는 대개 다른 시스템을 경유하여 일어나며 대표적으로는 외부에 오픈되어 있는 웹서버를 통하여 발생할 수 있습니다. 따라서, 웹서버를 경유한 해킹 방지를 위한 조치가 필요합니다.

해 설

- 웹서버를 통한 해킹 방지를 위해 웹 취약점 진단을 정기적으로 실시하여 보완하거나 웹 방화벽을 통해 웹서버 자체에 대한 공격을 효과적으로 차단합니다.
- 웹 취약점 진단
 - 해커는 웹 서버 자체의 취약점을 직접 공격하거나 웹 어플리케이션의 취약점을 공격하여 개인정보를 유출합니다. DB에 외부로부터 접근할 수 있는 거의 유일한 통로이므로 웹 취약점에 대한 공격이 집중적으로 이루어져 대부분의 개인정보 유출사고의 경로가 됩니다.
 - DB접근제어 솔루션을 적용하더라도 SQL Injection 등의 취약점 공격을 완벽히 막기는 어려우므로 웹 어플리케이션의 취약점 제거를 통해 이를 사전 방지해야 합니다.
 - 해킹기술이 발달하고 서비스 환경이 변화함에 따라 취약점은 계속 신규 발생하고 있으므로 연 1회 이상 정기적인 웹 취약점 점검이 필요하며, 긴급한 취약점 발생 시에는 추가적인 취약점 점검을 통한 보완 조치가 필요합니다.
- 웹 방화벽
 - 웹서버를 통해 DB정보를 유출하고자 하는 SQL Injection, 웹서버 자체를 해킹하고자 하는 웹쉘 등의 공격을 효과적으로 방어하여 웹 해킹을 방지합니다.
- 웹취약점 점검 현황 및 조치결과, 주기적 점검계획 등이 포함된 증적자료나 웹 방화벽 운영현황 등 웹서버 보호조치 현황을 '위험도 분석 결과보고서'에 첨부합니다.

26. 웹서버 프로그램과 운영체제 보안패치를 제조사 공지 후 지체 없이 수행하고 있습니까?

취 지

- 보안패치는 운영체제나 응용프로그램에 내재된 보안 취약점을 보완하는 소프트웨어로 보안패치를 할 경우 취약점을 이용하는 악성코드 감염을 방지합니다.

해 설

- 운영체제나 응용프로그램의 보안 취약점은 해커에 의한 공격 경로를 제공할 수 있으므로 운영체제 제조사 등에서 업데이트 공지가 있는 경우 최신 보안패치를 적용합니다.
- '지체 없이'란 현재 운영 중인 응용프로그램과의 업무연속성, 시스템에 미칠 영향 등을 고려하여 적용하기까지 소요되는 합리적인 시간을 의미합니다.
- 웹서버의 보안패치 현황 등 증적자료를 '위험도 분석 결과보고서'에 첨부합니다.

3. 위험도 분석 결과보고서

작성일	년 월 일	작성자	(소속)	(성명)
개인정보파일명				

(작성 예시)

< 목 차 >

I. 현황 조사

1. 개인정보파일 현황 (※ 고유식별정보 항목 및 암호화 현황 포함)
2. 고유식별정보 현황
3. 네트워크 및 시스템 구성도

II. 기관 기준 보호조치 현황

1. 정책 기반 보호조치

- 조직도, 책임자, 역할 및 책임
- 내부 관리계획 및 침해사고 대응계획 수립 현황
- 외주 보안관리 현황
- S/W 사용 정책
- 개인정보취급자 교육 현황

2. 네트워크 기반 보호조치

- IP 접근통제 및 서비스 포트 제한 현황
- 정보보호시스템 운영 및 모니터링 현황
- 네트워크 바이러스 차단 현황
- 네트워크 접속기록 관리 및 분석 현황
- 네트워크 장비 및 정보보호시스템 업데이트 현황 (※ 보안패치 및 패턴갱신 등 포함)

III. 개인정보처리시스템 기준 보호조치 현황

1. DB 및 Application 기반 보호조치

- DB 접근 통제 현황
- DB서버 서비스 포트 제한 현황
- DB 접속기록 관리 및 모니터링 현황
- 관리자 PC 네트워크 분리 현황
- DB접근 권한 부여 현황 및 변경·말소 내역
- 비밀번호 관리 정책 및 현황
- 물리적 접근 통제 현황
- 보조저장매체 이용 관리 현황
- 운영체제 보안패치 현황 (※ DB서버 및 DB서버 접속 단말기 포함)
- DB저장매체 불용처리 절차 및 현황

2. 웹 기반 보호조치

- 웹 취약점 점검 현황 및 결과 (※ 조치결과, 주기적 점검계획 등 포함)
- 웹 서버 보호조치 현황 (※ 웹방화벽 운영현황 등)

IV. 위험도 분석 결과

- 위험도 분석 점검에 의한 암호화 여부 판정 결과 등

- '위험도 분석 결과보고서'에는 위험도 분석 기준 작성에 대한 증거와 위험도 분석 점검에 따른 암호화 여부 등 위험도 분석 결과를 작성합니다.
- 개인정보처리자는 위험도 분석 점검 내용에 대한 입증책임이 있으며, 허위 작성을 방지하기 위하여 '위험도 분석 기준'의 점검 항목에 "예"로 체크했다면 그에 대한 증거를 명시하여야 합니다.
- '위험도 분석 점검 항목'에서 어느 하나의 점검항목이라도 "아니오"에 해당하는 경우, 암호화에 상응할만한 충분한 보호조치가 이루어지고 있다고 볼 수 없으므로 암호화에 상응하는 조치를 이행하거나 해당 개인정보파일에 대해 암호화 조치를 수행합니다.
- '위험도 분석 점검 항목'과 '위험도 분석 결과보고서'는 개인정보 보호책임자 또는 해당 부서 장의 결재를 득한 후 보관합니다.
- 개인정보처리시스템 증설, 내·외부망 연계 등 기타 운영환경이 변경된 경우 위험도가 새롭게 발생 될 수 있으므로 위험도 분석을 지속적으로 실시하여 개인정보의 안전한 관리가 가능하도록 조치합니다.